Note de pré-projet : Sentinelle

Équipe Harmattan · École Polytechnique de Ouagadougou · Challenge « La messagerie souveraine de l'administration »

1. Concept

Les agents de l'État échangent des informations de service, parfois sensibles, sur des messageries grand public dont les serveurs et les règles échappent à l'administration. **Sentinelle** est une messagerie instantanée (messages, groupes, fichiers) aussi simple à utiliser qu'une application du marché, mais **hébergée par l'État, chiffrée de bout en bout et réservée aux agents enrôlés**. Son originalité est un **portail d'administration souveraine** qui rend la sécurité *pilotable* : on enrôle, on classe, on révoque et on prouve, sans jamais pouvoir lire un message.

2. Architecture

Navigateur (Element Web) → Caddy (proxy) → Synapse (serveur Matrix) → PostgreSQL ; Keycloak assure l'identité (SSO, second facteur, rôles) ; le portail (FastAPI) pilote Keycloak et l'API d'administration de Synapse sur le réseau interne. Tout démarre avec `docker compose up -d --build`, sans service tiers. Les clients Element chiffrent et déchiffrent dans le navigateur : le serveur ne reçoit que du chiffré.

3. Protocole de chiffrement retenu

Matrix : Olm (échange de clés entre appareils) et Megolm (chiffrement des conversations de groupe), via Element Web (bibliothèque vodozemac). Le chiffrement est activé par défaut sur toutes les salles et imposé à la création des canaux institutionnels. **Aucune cryptographie n'est développée par l'équipe.** Choix motivé par la maturité du protocole, ses groupes chiffrés, ses fichiers chiffrés et l'existence d'un client web complet et d'un serveur auto-hébergeable.

4. Composants open source et licences

Synapse (AGPL-3.0), Element Web (AGPL-3.0 ou GPL-3.0), Keycloak (Apache-2.0), PostgreSQL (licence PostgreSQL), Caddy (Apache-2.0), FastAPI, HTTPX, Authlib, Jinja2 (MIT ou BSD-3). Liste complète avec liens : `THIRD_PARTY.md`. Code original publié sous **AGPL-3.0**.

5. Niveau d'engagement open source

Étendre et adapter : Element Web et Synapse, configurés et durcis (fédération, présence, aperçus d'URL, inscription et mots de passe désactivés, rôle exigé à la connexion), étendus par un composant original, le **portail d'administration** (`portal/`, environ 1 300 lignes de code et de tests, 48 tests automatisés).

6. Fonctionnalités innovantes (démontrées)

- **Révocation unique, vérifiée et tracée** : un clic désactive le compte Keycloak, ferme ses sessions, désactive le compte Matrix, supprime tous ses appareils et le retire de ses salles, puis contrôle le résultat (compte inactif, 0 appareil, 0 salle). La durée est mesurée et inscrite au journal : **1,2 s** relevée lors de notre essai (Keycloak 561 ms, Synapse 106 ms, vérification 536 ms), avec reconnexion refusée ensuite. En cas d'erreur, une **réactivation encadrée et tracée** rouvre le compte avec un nouveau mot de passe et un nouveau second facteur (sans appareil ni salle : ce n'est pas un retour en arrière).
- **Annuaire officiel et enrôlement** par ministère et par fonction ; création du compte Matrix liée à l'identité Keycloak, sans aucun mot de passe Matrix.
- **Canaux institutionnels classifiés** : *Diffusion restreinte* (30 jours) et *Confidentiel* (24 heures) ; salles sur invitation, chiffrées dès la création, avec **expiration automatique côté serveur** (la purge se base sur l'horodatage, sans lire le contenu). Les agents du ministère choisi sont invités automatiquement ; les agents révoqués jamais, ni les administrateurs de sécurité (séparation des tâches : seul le responsable désigné rejoint le canal).
- **Conformité du second facteur** : liste des agents actifs n'ayant pas configuré leur TOTP.
- **Preuve intégrée** : un outil inspecte la base et les médias et démontre qu'aucun message ni fichier n'est en clair.

Pertinence pour le Burkina Faso : souveraineté des échanges administratifs, administration simple (une seule équipe peut enrôler et révoquer des centaines d'agents), fonctionnement sur un serveur modeste, aucune dépendance à un service étranger.

7. Répartition des rôles

Membre	Filière	Responsabilités principales
Cramer	Génie des Télécommunications, Réseaux et Télécommunications	Infrastructure et réseau : Docker Compose, proxy Caddy, isolement des origines, métadonnées et durcissement, partie réseau de la note de sécurité
Alfred	Génie Informatique, Génie Logiciel	Portail d'administration, intégration Keycloak et Synapse, tests automatisés, historique Git
[Prénom NOM]	Génie Informatique, IA et Data science	Coordination, conformité et journal d'audit, documentation (README, notes), scénarios de démonstration et vidéo

Chaque membre sait expliquer le chiffrement, l'authentification et la révocation (voir `docs/DEMO_JURY.md`).